

# Fiche de Révision Exhaustive - Droit de la Cybersécurité

Basé sur les Séances 1 et 2 - Préparation QCM (ECAM LaSalle)

## 1. Cadre Général et Administratif

- **Évaluation** : 100% contrôle continu (2 QCMs comptant pour 50%, Participation pour 50%). Pas d'examen final.
- **Outils d'examen** : Utilisation obligatoire de l'ordinateur personnel et du logiciel **Safe Exam Browser (SEB)** qui verrouille l'écran. Interdiction du téléphone sous peine d'exclusion.
- **Définition de la participation** : Apporter au groupe, s'opposer, développer. Dire "je n'ai pas compris" ne compte pas.

## 2. Fondamentaux de la Cybersécurité & Chiffres Clés

- **Système d'Information (SI)** : Ensemble des moyens permettant de **collecter, stocker, traiter et diffuser** l'information. (Une banque sans son SI = 0 euro).
- **Définition de la cybersécurité** : On est concerné dès qu'on utilise un système informatique transmettant des données personnelles, ou par ricochet (proche touché).
- **L'humain** : C'est le maillon faible, la plus grande faille de sécurité. L'ingénierie sociale l'exploite.
- **Statistiques nationales** : 9 Français sur 10 confrontés à la cybermalveillance. 70% victimes de phishing (hameçonnage). **47% des victimes ont moins de 44 ans** (ce qui signifie que les >44 ans sont surreprésentés proportionnellement à leur usage).
- **Bonnes pratiques (Hygiène numérique)** : Mots de passe via gestionnaire (ex: Bitwarden), Double authentification (2FA/MFA), Mises à jour, HTTPS, Chiffrement WPA3 pour le Wi-Fi, Sauvegardes redondantes (règle de 3 dont 1 physique déconnectée). Combiner ces pratiques élimine **9 négligences évitables sur 10**.

## 3. Légalité vs Éthique & Droit Pénal

- **Le droit arrive toujours après** : Le droit (le bouclier) réagit toujours à un fait survenu, il a toujours un temps de retard sur l'attaque (l'épée).
- **Éthique vs Légalité** : L'éthique est personnelle et non contraignante (ex: "Test de l'oreiller"). Le droit est écrit et contraignant. **Ce qui est légal n'est pas toujours éthique et inversement.**
- **Exemples clés** :
  - **Obligation alimentaire** : Légale pour ascendants/descendants, mais seulement éthique/morale envers la fratrie.
  - **Billet de 50€ trouvé** : Aucune infraction pénale de le ramasser.
- **Vol** : Entrer en possession d'un bien de manière **illégal**.
- **Abus de confiance** : Entrer en possession d'un bien de manière **légal** (remis pour un usage précis), mais le détourner de sa finalité (ex: ramener un caddie chez soi, garder son PC pro après démission).

- **Responsabilité civile** : Basée sur l'article **1240 du Code Civil** (réparer un préjudice causé). Indépendante de la responsabilité pénale.
- **Cyberharcèlement** : Caractérisé par la **répétition**. Peine de base : 2 ans de prison et 30 000€ d'amende.  
**Circonstance aggravante** : harcèlement en meute (organisé à plusieurs).

## 4. Acteurs Institutionnels et Rôle de l'État

- **Séparation des pouvoirs** : Législatif (Parlement = vote la loi), Exécutif (Gouvernement/PM = applique la loi), Judiciaire.
- **L'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information)** : Agence de l'État, rattachée au SGDSN, donc au **Premier ministre (pouvoir exécutif)**.
- **Les 5 missions de l'ANSSI** :
  1. **Défendre** : Protéger les SI critiques, réagir aux attaques.
  2. **Connaître** : Veille des menaces, expertise.
  3. **Partager** : Diffuser recommandations, former.
  4. **Accompagner** : Sensibiliser, aider les opérateurs régulés.
  5. **Réguler** : Dimension juridique (règlements, sanctions).
- **Différence ANSSI / CNIL** : ANSSI = exécutif et protection SI. CNIL = fonctionnement indépendant/juridique, liée aux données perso/RGPD.
- **NSA** : National Security Agency (États-Unis), agence de renseignement.
- **Plateformes d'aide** : **17Cyber.fr**, Cybermalveillance.fr, le 17 (Police/Gendarmerie).
- **Procédure fraude bancaire** : 1. Appeler la banque. 2. Opposition carte. 3. Plainte.

## 5. Droit Européen : Les Bases

- **Périmètres** : Union Européenne = 27 États. Zone Euro = 21 États. **Espace Économique Européen (EEE) = 30 États** (UE + Norvège, Islande, Liechtenstein, 455M d'habitants).
- **Règlement européen** : Loi directement et intégralement applicable dans tous les États (ex: RGPD - *noté à tort directive à l'oral*).
- **Directive européenne** : Loi fixant une **obligation de résultat**, mais laissant aux États une marge de manœuvre sur les moyens. Elle doit être **transposée** en droit interne.
- **Processus législatif** : La Commission propose, le Conseil de l'UE et le Parlement européen votent (codécision).
- **TFUE** : Traité sur le Fonctionnement de l'Union Européenne (Traité de Rome > Maastricht > Lisbonne).  
**Article 114** : Base juridique pour le marché intérieur (et de NIS 2).

## 6. La Directive NIS 2 (Cœur du cours)

- **Identité** : Directive (UE) 2022/2555. Abroge et remplace NIS 1 (2016). Focus sur la **cyberrésilience** (résister + s'améliorer).
- **Les 5 premiers considérants (Exposé des motifs)** :
  1. **Rappel** : NIS 1 devait créer des capacités cyber et assurer la continuité des services (ex: PCA, site de repli).
  2. **Bilan NIS 1** : Positif (a joué un rôle de catalyseur) mais insuffisant face aux menaces actuelles.

3. **Contexte** : Numérisation rapide, explosion des cybermenaces (plus nombreuses, sophistiquées). Contexte pré-IA générative.
  4. **Diagnostic (Art. 114 TFUE)** : Problème majeur de **disparités de transposition** de NIS 1 entre les États membres (exigences et sanctions hétérogènes), ce qui fragilise le marché intérieur.
  5. **Objectif NIS 2** : Harmoniser la cybersécurité avec un cadre réglementaire commun, supprimer les divergences, mettre à jour les secteurs.
- **Entités visées** : **Entités essentielles** (ex: banques, énergie, santé - Annexe I) et **Entités importantes** (ex: chimie, industrie - Annexe II).
  - **Délais de notification d'incident** :
    - Alerte précoce : **24h** maximum.
    - Notification détaillée : **72h** maximum.
    - Rapport final : **1 mois**.
  - **Sanctions maximales** :
    - Entités essentielles : **10 Millions € ou 2%** du CA mondial (le plus élevé).
    - Entités importantes : **7 Millions € ou 1,4%** du CA mondial.
  - Gouvernance (Art. 20) : La direction (humains) doit valider les mesures et est responsable.

## 7. Surveillance de Masse et Lanceurs d'Alerte

- **Affaire Snowden (2013)** : Fuite de la NSA (via Rubik's Cube). A révélé que la surveillance ne ciblait plus que les suspects (logique pré-11/09), mais l'ensemble de la population de façon indiscriminée (collecte en amont).
- **Argument "Je n'ai rien à cacher"** : Argument fallacieux. Le professeur compare : "C'est comme dire que je me moque de la liberté d'expression car je n'ai rien à dire". Avoir une vie privée n'est pas être coupable.
- **Effet de la surveillance** : Modifie le comportement humain (chilling effect).
- **Fichiers et scores** :
  - Chine : Crédit social (affichage public des mauvais payeurs).
  - France : FICOBA (Fichier des comptes bancaires, non public, pour huissiers/banques).
- **Lanceurs d'alerte** : Snowden, Assange (WikiLeaks). Une directive européenne les protège.

# QCM d'Entraînement - 50 Questions

---

**Question 1 : Quelle est la pondération des examens dans la note finale de ce cours ?**

- a. 100% Examen final
- b. 50% QCM, 50% Participation
- c. 30% QCM, 70% Projet
- d. 100% QCM

**Question 2 : Quel logiciel est obligatoire pour passer les examens sur ordinateur ?**

- a. Safe Exam Browser (SEB)
- b. LockDown Browser
- c. Moodle Exam Shield
- d. Chrome Kiosk

**Question 3 : D'après le cours, qui est concerné par la cybersécurité ?**

- a. Seulement les grandes entreprises
- b. Seulement l'État et l'armée
- c. Toute personne utilisant un système informatique transmettant des données
- d. Uniquement les professionnels de l'informatique

**Question 4 : Quel est le maillon considéré comme la plus grande faille en cybersécurité ?**

- a. Le réseau Wi-Fi
- b. L'humain
- c. Les vieux systèmes d'exploitation
- d. Les mots de passe courts

**Question 5 : Quelle est la définition d'un Système d'Information (SI) vue en cours ?**

- a. Un lieu de stockage de serveurs (Data Center)
- b. Un ensemble de moyens pour collecter, stocker, traiter et diffuser l'information
- c. Un logiciel de gestion de base de données
- d. Le réseau interne (Intranet) d'une entreprise

**Question 6 : Selon les statistiques citées en cours, quelle proportion de Français a déjà été confrontée à une cybermalveillance ?**

- a. 5 sur 10
- b. 7 sur 10
- c. 9 sur 10
- d. 1 sur 10

**Question 7 : Quelle proportion des victimes de fraudes en ligne a moins de 44 ans (selon le cours) ?**

- a. 25%
- b. 47%
- c. 65%
- d. 80%

**Question 8 : Quelle est l'interprétation donnée au fait que 47% des victimes ont moins de 44 ans ?**

- a. Les jeunes sont les plus naïfs
- b. Les plus de 44 ans (53%) sont proportionnellement plus touchés au vu de leur utilisation
- c. L'âge n'a aucune influence sur la cybersécurité
- d. Les moins de 44 ans utilisent moins Internet

**Question 9 : Combien de négligences évitables sur 10 peut-on empêcher avec une bonne hygiène numérique ?**

- a. 5 sur 10
- b. 7 sur 10
- c. 9 sur 10
- d. 10 sur 10

**Question 10 : Quel est le bon ordre d'action en cas de fraude constatée sur son compte bancaire ?**

- a. Plainte > Opposition > Banque
- b. Banque > Plainte > Opposition
- c. Opposition > Banque > Plainte
- d. Banque > Opposition > Plainte

**Question 11 : À quel pouvoir l'ANSSI est-elle rattachée ?**

- a. Au pouvoir législatif
- b. Au pouvoir judiciaire
- c. Au pouvoir exécutif (Premier ministre via SGDSN)
- d. À aucun, c'est une autorité indépendante

**Question 12 : Laquelle de ces missions n'appartient PAS aux 5 missions de l'ANSSI ?**

- a. Défendre
- b. Connaître
- c. Sanctionner pénalement
- d. Accompagner

**Question 13 : Quelles sont les 5 missions exactes de l'ANSSI ?**

- a. Défendre, Connaître, Partager, Accompagner, Réguler
- b. Protéger, Surveiller, Arrêter, Juger, Informer
- c. Auditer, Sanctionner, Certifier, Poursuivre, Financer
- d. Défendre, Attaquer, Espionner, Réguler, Financer

**Question 14 : Quelle est la grande différence de nature entre l'ANSSI et la CNIL ?**

- a. La CNIL dépend du Premier ministre, l'ANSSI est indépendante
- b. L'ANSSI dépend de l'exécutif, la CNIL a un fonctionnement plus indépendant/juridique
- c. Il n'y en a pas, les deux sont des agences militaires
- d. L'ANSSI gère le RGPD, la CNIL gère les attaques

**Question 15 : Quel site public est dédié au signalement des cyberviolences et du cyberharcèlement ?**

- a. 17Cyber.fr
- b. StopViolence.gouv
- c. Cyber-Aide.fr
- d. Internet-Signalement.fr

**Question 16 : Quelle affirmation résume la différence entre droit et éthique ?**

- a. Le droit n'est pas écrit, l'éthique l'est
- b. L'éthique est punie par le juge, pas le droit
- c. Ce qui est légal n'est pas forcément éthique (et inversement)
- d. Droit et éthique sont des synonymes exacts

**Question 17 : Selon le Code civil, l'obligation alimentaire s'applique obligatoirement envers :**

- a. Sa fratrie (frères/sœurs)
- b. Ses ascendants et descendants
- c. Ses cousins
- d. Ses amis proches

**Question 18 : En droit français, ramasser un billet de 50€ tombé par terre, après le départ de son propriétaire, constitue :**

- a. Un vol
- b. Un abus de confiance
- c. Une extorsion
- d. Aucune infraction pénale

**Question 19 : Comment définit-on juridiquement le vol ?**

- a. Entrer en possession d'un bien de manière légale puis le détourner
- b. Entrer en possession d'un bien de manière illégale
- c. Ne pas payer une facture à temps
- d. Trouver un objet perdu

**Question 20 : Comment définit-on l'abus de confiance ?**

- a. Entrer en possession d'un bien illégalement
- b. Faire confiance à un inconnu sur internet
- c. Entrer en possession d'un bien légalement pour un usage précis, mais le détourner de sa finalité
- d. Pirater un compte bancaire avec de faux documents

**Question 21 : Garder le matériel professionnel (ordinateur) après avoir démissionné de son entreprise constitue :**

- a. Un vol
- b. Un abus de confiance
- c. Un recel
- d. Une appropriation légitime

**Question 22 : Payer ses courses au supermarché, puis ramener le caddie chez soi et le garder constitue :**

- a. Un vol
- b. Un abus de confiance
- c. Un emprunt non déclaré
- d. Aucune infraction

**Question 23 : En droit pénal, quel élément est central pour caractériser le harcèlement ?**

- a. La gravité d'un acte unique
- b. L'utilisation d'Internet
- c. La répétition d'actes
- d. Le vol de données

**Question 24 : Quelles sont les peines de base évoquées pour cyberharcèlement ?**

- a. 6 mois et 5 000€
- b. 2 ans d'emprisonnement et 30 000€ d'amende
- c. 5 ans et 100 000€
- d. Seulement des travaux d'intérêt général

**Question 25 : Quelle est la circonstance aggravante spécifique du harcèlement évoquée en cours ?**

- a. L'utilisation d'un VPN
- b. Le harcèlement en meute (à plusieurs, même indépendamment)
- c. Le harcèlement de nuit
- d. Le harcèlement par un mineur

**Question 26 : L'article 1240 du Code civil concerne :**

- a. La responsabilité pénale
- b. La responsabilité civile (réparation d'un préjudice)
- c. Les règles du cyberharcèlement
- d. Le droit à l'image

**Question 27 : Que signifie la métaphore 'Le bouclier et l'épée' en droit de la cybersécurité ?**

- a. Le droit (bouclier) arrive toujours après l'attaque (épée)
- b. Le droit est plus fort que les hackers
- c. L'ANSSI est le bouclier, la CNIL est l'épée
- d. La technique protège mieux que le droit

**Question 28 : Qui a révélé en 2013 l'existence des programmes de surveillance de masse de la NSA ?**

- a. Julian Assange
- b. Edward Snowden
- c. Mark Zuckerberg
- d. Bill Gates

**Question 29 : Comment les données Snowden ont-elles été physiquement exfiltrées d'Hawaï ?**

- a. Via le Cloud
- b. Dans un Rubik's Cube (cartes mémoire)
- c. Sur un disque dur crypté envoyé par la Poste
- d. Par email chiffré

**Question 30 : Quel changement de paradigme le renseignement a-t-il connu après le 11 septembre 2001 ?**

- a. On ne surveille plus personne
- b. On cible uniquement les chefs d'État
- c. On collecte toutes les données en amont de manière indiscriminée, au lieu de partir d'un suspect
- d. On a interdit la surveillance numérique

**Question 31 : Que répond le professeur à l'argument 'La surveillance ne me dérange pas car je n'ai rien à cacher' ?**

- a. C'est vrai, seuls les criminels sont visés
- b. C'est faux, la surveillance coûte trop cher
- c. C'est comme dire 'Je me moque de la liberté d'expression car je n'ai rien à dire'
- d. C'est exact en droit français

**Question 32 : Quel effet comportemental la surveillance de masse provoque-t-il chez les individus ?**

- a. Ils deviennent plus productifs
- b. Ils changent leur comportement car ils se savent observés (effet dissuasif)
- c. Ils achètent plus en ligne
- d. Aucun effet documenté

**Question 33 : Qu'est-ce que le FICOPA en France ?**

- a. Un système de crédit social
- b. Le Fichier des Comptes Bancaires (consultable par huissiers/banquiers)
- c. L'agence de cybersécurité
- d. Le syndicat des hackers éthiques

**Question 34 : Qui a fondé WikiLeaks et fait face à des procédures judiciaires internationales ?**

- a. Edward Snowden
- b. Julian Assange
- c. Chelsea Manning
- d. Elon Musk

**Question 35 : L'utilisation du HTTPS permet de :**

- a. Empêcher totalement la NSA de lire vos données
- b. Chiffrer le trafic pour rendre la collecte de masse plus difficile et coûteuse
- c. Bloquer les virus
- d. Accélérer la connexion Internet

**Question 36 : Combien de pays composent l'Espace Économique Européen (EEE) visé par la directive NIS 2 ?**

- a. 21
- b. 27
- c. 30
- d. 45

**Question 37 : Quelle est la principale caractéristique d'un Règlement européen ?**

- a. Il n'est pas obligatoire
- b. Il doit être transposé par chaque État membre
- c. Il est directement et intégralement applicable dans tous les États membres
- d. Il ne s'applique qu'aux entreprises de plus de 500 salariés

**Question 38 : Quelle est la principale caractéristique d'une Directive européenne ?**

- a. Elle fixe une obligation de résultat et nécessite une transposition en droit interne
- b. Elle s'applique directement sans transposition
- c. Elle donne de simples conseils facultatifs aux États
- d. Elle est votée uniquement par la Commission européenne

**Question 39 : Qu'est-ce que la transposition d'une directive ?**

- a. Sa traduction dans les 24 langues de l'UE
- b. Son intégration dans le droit national (codes) par chaque État membre
- c. Son annulation par un juge
- d. Son approbation par référendum

**Question 40 : Quel est le texte juridique suprême de l'Union européenne actuellement en vigueur ?**

- a. La Constitution de 1958
- b. Le Code Civil Européen
- c. Le Traité sur le Fonctionnement de l'Union Européenne (TFUE)
- d. La Charte des Nations Unies

**Question 41 : Quelle directive NIS 2 vient-elle abroger et remplacer ?**

- a. Le RGPD
- b. La directive e-Privacy
- c. La directive NIS 1 de 2016
- d. La directive IA

**Question 42 : Sur quelle base juridique du TFUE la directive NIS 2 est-elle fondée ?**

- a. Article 42 (Défense)
- b. Article 114 (Fonctionnement et harmonisation du marché intérieur)
- c. Article 50 (Retrait de l'UE)
- d. Article 102 (Concurrence)

**Question 43 : Selon le considérant 4 de NIS 2, quel était le principal problème de NIS 1 ?**

- a. Son coût financier
- b. L'obsolescence des technologies
- c. De fortes disparités de mise en œuvre entre les États membres
- d. Son rejet par les grandes entreprises

**Question 44 : Que signifie la cyberrésilience au sens de NIS 2 ?**

- a. Ne jamais subir de cyberattaque
- b. Capacité à résister à une attaque, rebondir et s'améliorer
- c. Capacité à attaquer les pirates
- d. Capacité à payer les rançons rapidement

**Question 45 : Quel est l'objectif premier de la directive NIS 2 (considérant 5) ?**

- a. Sanctionner les GAFAM
- b. Supprimer les divergences entre États via des règles harmonisées
- c. Créer un internet européen fermé
- d. Remplacer l'ANSSI par une agence européenne unique

**Question 46 : Quelles sont les deux catégories d'entités créées par NIS 2 ?**

- a. Publiques et Privées
- b. Nationales et Internationales
- c. Essentielles et Importantes
- d. Critiques et Mineures

**Question 47 : Dans NIS 2, quel est le délai maximal pour émettre une 'alerte précoce' après avoir eu connaissance d'un incident ?**

- a. 12 heures
- b. 24 heures
- c. 48 heures
- d. 72 heures

**Question 48 : Dans NIS 2, quel est le délai pour fournir la 'notification d'incident' détaillée ?**

- a. 24 heures
- b. 48 heures
- c. 72 heures
- d. 1 mois

**Question 49 : Quelle est l'amende maximale prévue par NIS 2 pour une Entité Essentielle ?**

- a. 1 Million €
- b. 7 Millions € ou 1,4% du CA mondial
- c. 10 Millions € ou 2% du CA mondial
- d. 50 Millions €

**Question 50 : En lien avec NIS 2, que signifie 'PCA' évoqué par le professeur ?**

- a. Poste de Contrôle Avancé
- b. Plan de Continuité d'Activité
- c. Protocole de Chiffrement Asymétrique
- d. Plateforme de Cybersécurité Automatisée

**Question 51 : L'organe de direction (les dirigeants) d'une entité sous NIS 2 :**

- a. N'a aucun rôle, c'est l'affaire des informaticiens
- b. Doit approuver les mesures de gestion des risques et peut être tenu responsable
- c. Est exempté des règles de cybersécurité
- d. Doit coder lui-même les pare-feux

# Corrigé du QCM

|         |         |         |         |         |
|---------|---------|---------|---------|---------|
| Q1 : b  | Q12 : c | Q23 : c | Q34 : b | Q45 : b |
| Q2 : a  | Q13 : a | Q24 : b | Q35 : b | Q46 : c |
| Q3 : c  | Q14 : b | Q25 : b | Q36 : c | Q47 : b |
| Q4 : b  | Q15 : a | Q26 : b | Q37 : c | Q48 : c |
| Q5 : b  | Q16 : c | Q27 : a | Q38 : a | Q49 : c |
| Q6 : c  | Q17 : b | Q28 : b | Q39 : b | Q50 : b |
| Q7 : b  | Q18 : d | Q29 : b | Q40 : c | Q51 : b |
| Q8 : b  | Q19 : b | Q30 : c | Q41 : c |         |
| Q9 : c  | Q20 : c | Q31 : c | Q42 : b |         |
| Q10 : d | Q21 : b | Q32 : b | Q43 : c |         |
| Q11 : c | Q22 : b | Q33 : b | Q44 : b |         |